

SKYNET ROBOTICS

Rapport d'audit technique - Grey Box

Active Directory - Segmentation - Surface de mouvement latéral

Organisation auditee	Skynet Robotics
Modele	Audit grey box avec compte utilisateur fourni
Point d'entree	DESKTOP-T2GGFAF.skynet.lan - 10.0.1.2
Domaine	SKYNET / skynet.lan
Date du rapport	26 juin 2026

Synthese : aucune compromission complete avec ntuser, mais surface AD trop exposee depuis le VLAN utilisateur.

1. Synthèse exécutive

Conclusion courte

Le compte SKYNET\ntuser ne permet pas de compromission complète ni de mouvement latéral confirmé. En revanche, le contrôleur de domaine est trop accessible depuis un poste utilisateur, et la politique d'authentification du domaine est faible.

Chaîne de risque principale : poste utilisateur compromis -> accès direct au DC -> exposition

Kerberos/LDAP/SMB/RDP/WinRM -> politique de mot de passe faible -> risque accru d'énumération AD, password spraying interne et mouvement latéral si un identifiant privilégié est compromis.

ID	Constat	Criticité	Statut
F01	Politique de mot de passe AD faible	Élevée	Confirme
F02	Absence de verrouillage de compte	Élevée	Confirme
F03	DC accessible depuis VLAN utilisateur sur ports AD et admin	Élevée	Confirme
F04	RDP expose sur le contrôleur de domaine	Moyenne à élevée	Confirme
F05	WinRM expose sur le contrôleur de domaine	Moyenne à élevée	Confirme
F06	Compte samba-svc avec SPN et mot de passe sans expiration	Moyenne	Confirme
F07	SMB inter-VLAN vers éprouvette	Moyenne	Confirme
F08	Certificat RDP non approuvé	Faible à moyenne	Confirme
F09	Journalisation pare-feu Windows insuffisante	Faible	Confirme

2. Périmètre et environnement observé

2.1 Point d'entrée

Poste : DESKTOP-T2GGFAF.skynet.lan

Adresse source : 10.0.1.2

Utilisateur : SKYNET\ntuser

Système : Windows 10 Pro

Sous-réseau local : 10.0.1.0/28

Passerelle : 10.0.1.1

2.2 Systemes critiques identifiés

Nom	IP	Rôle observé	Exposition principale
DC1.skynet.lan	10.0.6.3	Contrôleur de domaine	AD, SMB, RDP, WinRM
eprouvette.skynet.lan	10.0.6.5	Serveur CIFS associé à samba-svc	SMB/445

3. Politique de mot de passe AD insuffisante

Criticité : Élevée

Preuve

net accounts /domain : Minimum password length = 7 ; Lockout threshold = Never ; Maximum password age = 42 ; Password history = 24.

Analyse

La longueur minimale de 7 caractères est faible pour un domaine Active Directory.

L'absence de verrouillage de compte est le point le plus sensible : un compte peut subir des tentatives répétées sans blocage automatique.

Impact

Risque accru de password guessing ou password spraying interne. Le risque est renforcé par l'accessibilité directe des services Kerberos, LDAP et SMB du contrôleur de domaine depuis le poste utilisateur.

Recommandations

- Fixer une longueur minimale à 14 caractères ou plus.
- Activer un seuil de verrouillage de compte.
- Surveiller les échecs d'authentification.
- Interdire les mots de passe compromis.
- Appliquer MFA sur les accès sensibles.

4. Segmentation insuffisante vers le contrôleur de domaine

Criticité : Élevée

Preuve

Depuis 10.0.1.2, les ports 53, 88, 135, 139, 389, 445, 464, 636, 3268, 3389 et 5985 sont ouverts sur DC1 / 10.0.6.3.

Analyse

Le poste utilisateur du sous-reseau 10.0.1.0/28 atteint directement le contrôleur de domaine situé en 10.0.6.3.

Certains flux AD sont nécessaires, mais l'exposition de RDP et WinRM vers un DC depuis un VLAN utilisateur est excessive.

Impact

Un poste utilisateur compromis peut interagir avec Kerberos, LDAP, SMB, RDP et WinRM du DC. Cela facilite l'énumération AD, les tentatives d'authentification internes et le mouvement latéral si un compte privilégié est compromis.

Recommandations

- Mettre en place un filtrage inter-VLAN deny-by-default.
- Autoriser uniquement les ports AD strictement nécessaires.
- Bloquer RDP et WinRM vers les DC depuis les VLAN utilisateurs.
- Réserver l'administration à un bastion ou VLAN admin.
- Journaliser les tentatives RDP/WinRM vers les DC.

5. RDP et WinRM exposés sur le contrôleur de domaine

Criticité : Moyenne à élevée

Preuve

RDP/3389 et WinRM/5985 sont accessibles sur DC1 depuis le poste utilisateur. RDP atteint l'authentification mais refuse SKYNET\ntuser.

Analyse

Le refus de connexion RDP pour ntuser est un contrôle positif. Il n'y a pas de latéralisation RDP confirmée.

Le problème reste l'exposition des interfaces d'administration distante depuis un VLAN utilisateur.

Impact

En cas de compromission d'un compte admin, ces services offriraient un chemin direct d'administration vers le contrôleur de domaine.

Recommandations

- Bloquer RDP et WinRM vers les DC depuis les VLAN utilisateurs.
- Limiter PowerShell Remoting aux groupes d'administration dédiés.
- Activer une alerte sur toute tentative RDP/WinRM vers un DC.
- Utiliser un bastion avec MFA.

6. Compte samba-svc avec SPN et mot de passe sans expiration

Criticite : Moyenne

Preuve

samba-svc : SPN = cifs/eprouvette.skynet.lan ; Password expires = Never ; Account active = Yes ; Global group = Domain Users.

Analyse

Le compte samba-svc est un compte de service actif avec SPN CIFS. Il n'est pas observé comme membre d'un groupe privilégié, mais son mot de passe n'expire jamais.

Ce type de compte peut être cible dans un scénario Kerberoasting si le mot de passe est faible. Aucun ticket n'a été extrait et aucun cracking n'a été effectué.

Impact

Si le secret du compte est faible ou réutilisé, sa compromission pourrait permettre un accès au service CIFS associé et faciliter un mouvement latéral.

Recommandations

- Convertir en gMSA si possible.
- Mettre un mot de passe long, aléatoire et unique.
- Retirer Password never expires.
- Limiter les droits et postes autorisés.
- Surveiller les demandes TGS sur le SPN.

7. SMB inter-VLAN accessible vers eprouvette

Criticite : Moyenne

Preuve

Test-NetConnection eprouvette.skynet.lan -Port 445 : TcpTestSucceeded = True ; Source = 10.0.1.2 ; Cible = 10.0.6.5.

Analyse

Le serveur eprouvette, situé dans le réseau 10.0.6.0/24, est accessible en SMB depuis le poste utilisateur.

Les accès C\$ et ADMIN\$ ont retourné Access denied. Aucun mouvement latéral SMB administratif n'a été confirmé.

Impact

L'exposition SMB inter-VLAN facilite l'énumération de partages et augmente l'impact d'une compromission d'identifiants.

Recommandations

- Limiter les flux SMB inter-VLAN aux besoins stricts.
- Vérifier les ACL SMB/NTFS.
- Restreindre les accès par groupes nominatifs.
- Surveiller les connexions SMB anormales.

8. Journalisation et certificat RDP

Criticité : Faible à moyenne

Preuve

Pare-feu Windows actif, mais LogAllowed = False et LogBlocked = False. Le client RDP affiche un certificat non approuvé sur DC1.

Analyse

Le pare-feu Windows est actif, ce qui est positif. En revanche, la journalisation locale des flux autorisés et bloqués n'est pas active.

Le certificat RDP du DC n'est pas approuvé par une autorité de confiance reconnue côté client.

Impact

La capacité d'investigation locale est réduite. Le certificat non approuvé peut faciliter des erreurs d'acceptation utilisateur et dégrader la confiance dans l'identité du serveur.

Recommandations

- Activer la journalisation des connexions bloquées au minimum.
- Centraliser les journaux Windows.
- Installer un certificat RDP issu d'une autorité interne approuvée.
- Vérifier le CN/SAN du certificat.

9. Tests négatifs et contrôles rassurants

Contrôle	Résultat
Privileges locaux	ntuser ne dispose pas de SeDebugPrivilege, SeBackupPrivilege, SeRestorePrivilege, SeImpersonatePrivilege, SeTakeOwnershipPrivilege ou SeLoadDriverPrivilege.
Admin local	ntuser n'est pas administrateur local. Les administrateurs locaux observés sont Admin, Administrator et SKYNET\Domain Admins.

Acces admin SMB	C\$ et ADMIN\$ refuses sur DC1 et eprouvette avec ntuser.
RDP DC	Le service RDP repond, mais ntuser n est pas autorise a ouvrir une session.
SYSVOL / NETLOGON	SYSVOL lisible comme attendu, NETLOGON vide, pas de cpassword, pas de script sensible, pas de secret en clair, ACL sans droit d ecriture pour les utilisateurs authentifies.
Defender	Defender actif, temps reel actif, signatures a jour, Tamper Protection active.

10. Plan de remediation priorise

Priorite	Theme	Action
P1	Authentification AD	Renforcer la longueur minimale, activer le verrouillage de compte, superviser les echecs, envisager MFA.
P1	Segmentation DC	Bloquer RDP/WinRM vers les DC depuis les VLAN utilisateurs. Filtrer les flux inter-VLAN.
P2	Comptes de service	Revoir samba-svc, retirer Password never expires, utiliser gMSA si possible.
P2	SMB inter-VLAN	Limiter les flux SMB et verifier les ACL des partages.
P3	Traçabilité	Activer logs pare-feu, centraliser journaux, alertes RDP/WinRM/SMB/LDAP/Kerberos.
P3	Certificats	Deployer un certificat RDP approuve sur les services critiques.

11. Conclusion

L'audit n'a pas permis de confirmer une elevation de privileges ni un mouvement lateral avec le compte SKYNET\ntuser.

Le compte est correctement limite localement : il n'est pas administrateur, ne possede pas de privilege Windows sensible et les acces administratifs distants ont ete refuses.

Les faiblesses principales sont structurelles : politique d'authentification faible, segmentation trop permissive vers le controleur de domaine, exposition RDP/WinRM du DC et hygiène insuffisante du compte de service samba-svc.

Le risque principal est une surface d'attaque interne trop permissive. En cas de compromission d'un poste utilisateur ou d'un compte privilegie, l'environnement offre des chemins credibles vers l'enumeration AD, les tentatives d'authentification internes et le mouvement lateral.